

AdvocateAuroraHealth

Title: AAH Enterprise Information Security & Chief Information Security Officer Standard		Document Number: 51931
Document Type: ☐ Policy ☐ Procedure ☐ Guideline ☒ Other Standard Work		Last Review/Revision Date: 12/16/2020
Content Applies to Patient Care: (Select all that apply) ☐ Adults ☐ Pediatrics (Under 18)	Content Applies to: (Select One) ☐ Clinical ☐ Administrative	Next Review Date: 12/16/2023
		Effective Date: 12/16/2020
Scope: ☐ AAH System ☐ ACH ☐ AAH IL Only ☐ AAH WI Only ☐ Site Only (Location Name): ☐ Department Only (Department Name): Health Informatics & Technology (HIT)		

I. PURPOSE

To establish an Enterprise Information Security (EIS) standard for Advocate Aurora Health (AAH) that ensures appointment and establishes responsibilities for a Chief Information Security Officer (CISO) per the HIPAA Security Rule.

II. SCOPE

This standard applies to Advocate Aurora Health, Inc. and any or all Information and Information Resources maintained by the HIT department.

III. DEFINITIONS/ABBREVIATIONS

Advocate Aurora Information: All information that is owned by Advocate Aurora or owned by third parties but provided to Aurora. For clarification purposes only, information remains "Advocate Aurora Information" even if it is in the possession and under the control of a third party (e.g., a third-party service provider and/or its subcontractors).

Advocate Aurora Information Resources: Any media, software, hardware or other technology that supports the use, access, processing, storage or transmission of Aurora Information.

Restricted Confidential Information: includes any Advocate Aurora Information that would be likely to result in liability or other harm (including reputational harm) to Advocate Aurora if disclosed without authorization.

Cybersecurity Breach: the unauthorized and/or impermissible acquisition, access, use, or disclosure of Legally Restricted Confidential Information and/or Advocate Aurora Restricted Confidential Information.

Information Security Policies: Policies which pertain to the protection of Advocate Aurora Information and Information Resources.

Legally-Restricted Confidential Information: includes any Advocate Aurora Information that is subject to laws or regulations related to its confidentiality, privacy, or security. Unauthorized disclosure of this information poses a significant risk and may result in criminal or civil fines, liabilities and breach notification obligations for Advocate Aurora.

IV. STANDARDS

- A. AAH appoints a CISO with the authority and resources to coordinate, develop, implement and maintain an EIS program.
 - 1. AAH's CISO also serving as the HIPAA Security Officer (HSO), is an AAH employee.
 - 2. CISO/HSO is responsible for coordinating compliance with the HIPAA Security Rule as defined by the Code of Federal Regulations, 45 C.F.R. 160, 162 and 164.
 - 3. The CISO/HSO may delegate his or her responsibilities to other team members.
- B. AAH shall establish and maintain an EIS Roles and Responsibilities Standard.
 - 1. This shall be reviewed annually by AAH Executive Board and Chief Information Officer (CIO).
 - 2. This must list roles within the organization the CISO/HSO can delegate responsibilities to.
 - 3. The document is required to be updated if roles within the organization change.

V. ROLES & RESPONSIBILITIES

Role	Responsibility
See EIS Standard Roles & Responsibilities: Workflow	1. See: Roles Column A

Role	Responsibility
See EIS Standard Roles & Responsibilities: Workflow	2. See: Responsibilities Row 2

VI. CROSS REFERENCES

Advocate Aurora Health Care Policies:	AAH IT Security Policies AAH Glossary of Defined Terms Used in HIPAA Policies and Procedure AAH Policy Privacy Program Overview AAH Policy HIPAA Privacy Breach Investigation and Notification AAH Policy Physical Security
Advocate Aurora Health Care HIT Standards:	None

VII. RESOURCES AND REFERENCES

List of References:	
Supported Compliance Controls:	HIPAA 164.308(a)(6), 164.308(a)(1), 164.308(a)(4), 164.312(a)(1) NIST 800-53 rev 4 PM-1 through PM-16

	PCI DSS 3.2 12.10, 6.3, 6.5 – 6.7, 3.6, 4.1 – 4.3
	HITRUST CSF v8.1 11.a, 11.c, 09.ab, 07.a, 09.o, 09.m, 07.d, 01.x, 06.h, 10.h, 10.b, 09.ae, 09.d, 10.i, 02.e
	CIS Critical Security Controls #1-Inventory of Authorized and Unauthorized Devices #2-Inventory of Authorized and Unauthorized Software #4-Continuous Vulnerability Assessment and Remediation #5-Controlled use of Administrative Privileges #13 – Data Protection #17-Security Skills Assessment and Appropriate Training to Fill Gaps #18 – Application Software Security #19 – Incident Response & Management #20-Penetration Tests and Red Team Exercises

VIII. APPENDICES

EIS Standard Roles and Responsibilities Standard